

EXECUTIVE SUMMARY

Finexa (example)

Digital infrastructure · Finexa SAS · SIREN 000 000 000 · Prepared by Firm consultant · For the attention of Thomas Lefèvre, deputy chief executive · Prepared on 30 September 2026

5 texts apply (GDPR, NIS2 (ReCyF), DORA, CRA, AI Act), i.e. 40 unified requirements. Reported coverage: 46%; 9 requirements with no measure at all, 17 partly covered.

APPLICABLE TEXTS

5 / 5

GDPR · NIS2 (ReCyF) ·
DORA · CRA · AI Act

COVERAGE

46%

36 / 40 requirements
assessed

WITH NO MEASURE

9

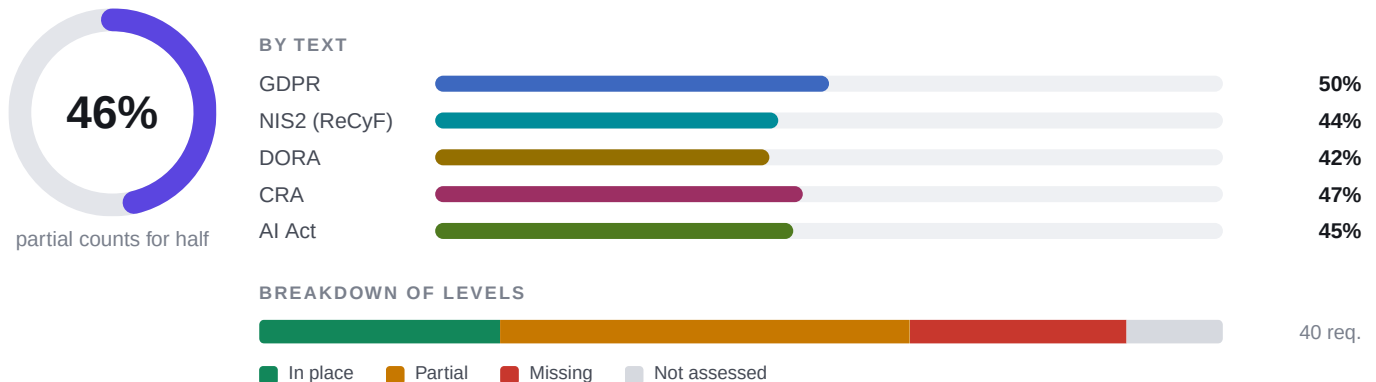
unified requirements

MAXIMUM PENALTY

€20M

GDPR cap

Current position



Regulatory exposure

TEXT	SCOPING OUTCOME	COVERAGE	PENALTY CAP
GDPR	Controller and processor, DPO required	50%	€20M
NIS2 (ReCyF)	Important entity	44%	€7M
DORA	Financial entity	42%	Not quantified
CRA	Manufacturer, default product	47%	€15M
AI Act	Deployer, limited risk	45%	€900k

Where to start

- Accountability of the management body** GDPR + NIS2 (ReCyF) + DORA + AI Act
Set up a single governance body (a security and compliance committee) that formally approves policies, monitors indicators and records its decisions. A single, properly drafted resolution counts as approval under each of these texts.
Today: missing · Owner: Executive management · Effort 3/5
- Documentation and policies** GDPR + NIS2 (ReCyF) + DORA + CRA + AI Act
Build a single documentation set, with a framework policy and topic policies, each carrying a mapping table to the articles it satisfies. This table is what turns an internal document into evidence of compliance.
Today: missing · Owner: Compliance · Effort 3/5

3

Notifying incidents to the authority

Build a single notification matrix (event, qualification, authority, deadline, template, owner) and rehearse it. The shortest clock drives the mobilisation of the crisis unit, even if the other deadlines are longer.

Today: missing · Owner: CISO · Effort 4/5

GDPR + NIS2 (ReCyF) + DORA + CRA + AI Act

Roadmap

Phase 1 · 0 to 3 months	Phase 2 · 3 to 6 months	Phase 3 · 6 to 12 months	Phase 4 · 12 to 24 months
5 requirements	5 requirements	10 requirements	20 requirements
· Accountability of the management body	· Testing, exercises and audits	· Regulatory registers	· Security detection and monitoring
· Documentation and policies	· Lex specialis: DORA prevails over NIS2	· Dedicated function and point of contact	· Incident management process
· Notifying incidents to the authority and 2 more	· Security maintenance and end of life and 2 more	· Training and awareness and 7 more	· Supply chain security and 17 more

Weak points by domain

Governance		30%	Resilience		10%
Risk		50%	Third parties		25%
Protection		75%	Data		100%
Detection		67%	Artificial intelligence		50%
Response		33%	Documentation		17%

Decisions required

- Approve phase 1 (5 requirements, 0 to 3 months) and its budget.
- Assign an owner to 10 requirements with a gap and no identified owner.
- Have the assessment completed: 4 requirements still to assess.
- Clear 1 point left to check during scoping (see the appendix of the full report).
- Decide on 1 mandatory requirement whose matching ISO 27001 control was excluded from the initiative.
- Follow the adoption of the NIS2 transposition act and set the resulting compliance timetable.

UPCOMING DEADLINES		IN CASE OF AN INCIDENT	
7 October 2026	Resilience bill debated in the National Assembly	GDPR	CNIL · from 72 h
2 December 2026	New prohibition and end of the marking grace period	NIS2 (ReCyF)	Reported under DORA
31 December 2026	Expected enactment of the resilience act	DORA	ACPR · from 4 h
		CRA	ENISA · from 24 h
		AI Act	Market surveillance authority · from 2 days

Committee decisions

NO.	DECISION TAKEN	OWNER	DUE DATE
1			
2			
3			
4			
Committee date: _____ Presented by: _____			

Prepared from the information provided and the law as of the date shown. It replaces neither advice from counsel nor the position of the competent authority. Details, legal bases and method: full scoping report.